

PatchIQ-iA Security Analysis

Sample 02 — Unsafe eval() Detection

1. Objective

The objective of this test is to evaluate whether PatchIQ-iA can detect unsafe use of Python's `eval()` function in a Pull Request. The submitted code directly passes user-controlled input to `eval()`, creating a potential arbitrary code execution vulnerability.

2. Input Code

The following vulnerable Python code was submitted as part of the Pull Request:

```
user_input = input("Enter Python expression: ")

result = eval(user_input)

print(result)
```

3. PatchIQ-iA Output

The following screenshot shows the actual security review generated by PatchIQ-iA for this Pull Request.

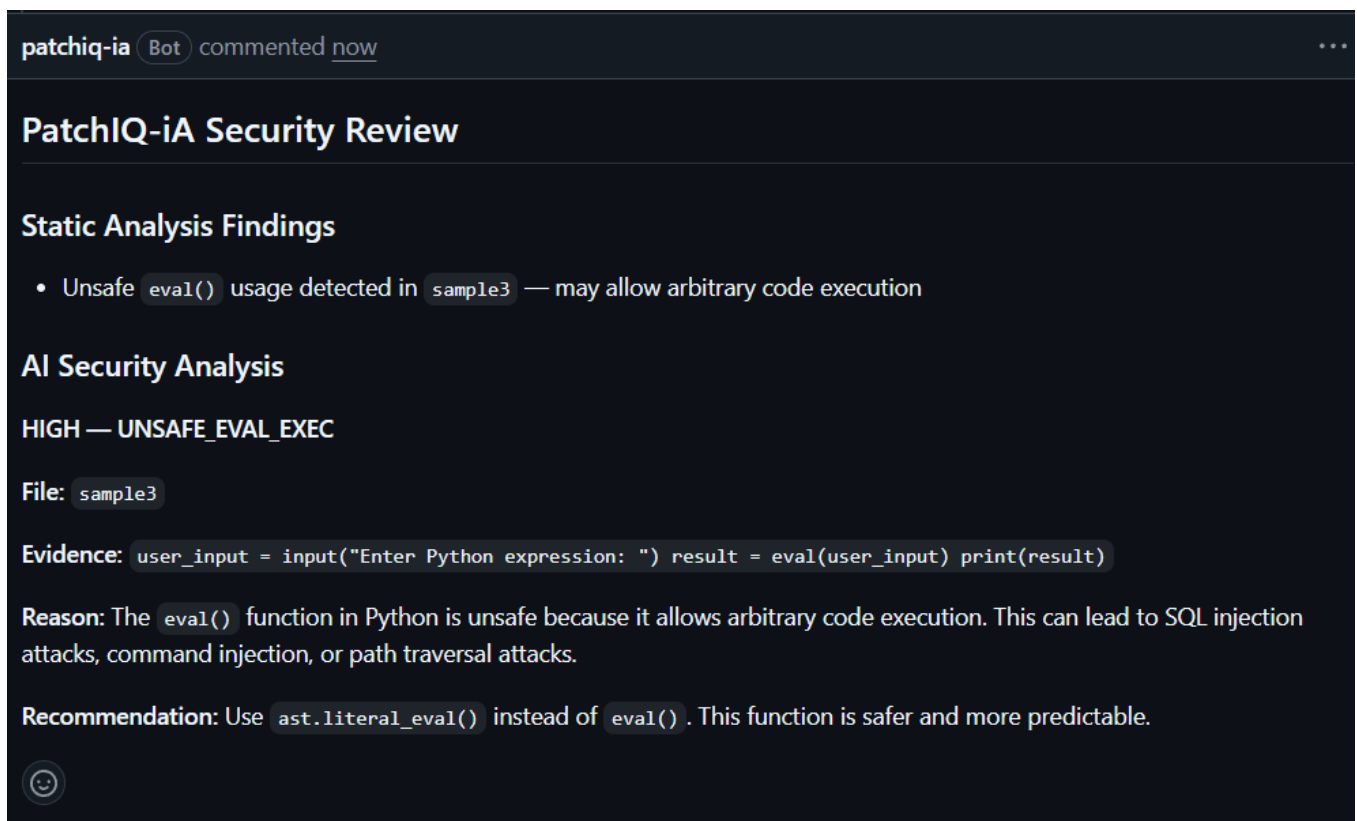


Figure 1. Actual PatchIQ-iA Security Review generated during the test.

4. Conclusion

PatchIQ-iA successfully detected the unsafe `eval()` usage through both static analysis and AI security analysis. The system classified the finding as HIGH severity and identified the use of `eval()` as a potential arbitrary code execution vulnerability. The AI analysis also provided evidence, reasoning, and a recommendation to use `ast.literal_eval()` instead of `eval()`.